

Projet de Fin d'Etudes

Pour l'obtention du diplôme

D'Ingénieur d'Etat

Génie Informatique

Promotion 2026

Mise en place d'une plateforme SaaS multi-sociétés
pour la gestion et la conformité ISO 27001:2022

Stage réalisé au sein de :
Alexsys Solutions

Réalisé par **M. Meriem El Fertas**

Soutenance le

Membres de jury :

M.
M.
M.

Encadrant ENSAF
Enseignant ENSAF
Enseignant ENSAF

Dédicace

*À cette âme partie vers l'au-delà mais restée dans mon cœur un ciel qui me protège..
À celle qui fut mon refuge et m'a appris la patience sans un mot. À toi, lumière de mes jours, je dédie
ce succès ; chaque pas franchi aujourd'hui porte ton empreinte éternelle.*

*À ma mère.. mon pilier et ma patrie..
Au cœur qui me porte à chaque chute et me donne la force de continuer. Merci d'être ce début qui ne
finit jamais.*

*À mon père.. mon soutien et ma sécurité..
À l'homme qui m'a appris la force par son silence et son combat. Merci d'avoir cru en moi quand je
doutais. Je te dédie ce succès, toi qui as été l'épaule solide portant tous mes rêves.*

*À mes sœurs, compagnes de mon âme..
Merci d'avoir été mon soutien dans l'épreuve. Vous êtes la famille que mon cœur choisit chaque jour
pour s'épanouir.*

*À mes amies.. À celles qui ont transformé mes doutes en espoirs par leurs rires. Grâce à vous, le
chemin fut plus léger. Je suis fière que nous soyons arrivées ensemble.*

*En conclusion..
"Celui qui ne remercie pas les gens ne remercie pas Dieu". À chaque cœur ayant laissé une trace,
merci d'avoir été une raison de ma persévérance.*

Remerciements

Avant même de poser les premiers mots de ce travail, je remercie Allah, Le Miséricordieux. C'est par Sa volonté que ce projet a vu le jour, et c'est grâce à Son soutien constant que j'ai trouvé la force d'avancer malgré les difficultés. Ce travail est, avant tout, le fruit de Sa grâce infinie, qui m'a guidée pas à pas jusqu'à son accomplissement. À Lui revient toute reconnaissance pour m'avoir accompagnée et accordé le courage tout au long de ce chemin.

Je tiens à exprimer ma profonde reconnaissance à toutes les personnes qui, de près ou de loin, ont contribué à la réalisation de ce travail, que ce soit par leur soutien, leurs conseils ou leur présence bienveillante, rendant cette expérience à la fois enrichissante et formatrice.

J'adresse mes sincères remerciements à mon encadrante, Pr. Zakaria MAZGOURI, pour la qualité de son accompagnement, la richesse de ses connaissances et la pertinence de ses orientations. Sa disponibilité, son suivi rigoureux ainsi que ses conseils avisés ont constitué un appui essentiel tout au long de ce projet. Je lui suis également reconnaissante pour la confiance qu'elle m'a accordée et pour l'ambition et la rigueur qu'elle m'a encouragée à développer.

Je souhaite également exprimer ma vive gratitude à mon encadrant externe, Mr MAAROUF Jihad, pour son encadrement, sa disponibilité et son soutien constant durant mon stage. Ses recommandations pertinentes, son professionnalisme et son sens du partage a grandement facilité mon intégration et contribué à la réussite de cette expérience. Mes remerciements s'adressent également à l'ensemble de l'équipe de ALEXSYS SOLUTIONS pour l'accueil chaleureux et l'environnement de travail stimulant qu'ils m'ont offert.

Je tiens aussi à remercier chaleureusement les membres du jury, Pr. et Pr., pour l'intérêt qu'ils ont porté à ce travail.

Enfin, j'exprime ma gratitude à l'ensemble du corps enseignant de l'École Nationale des Sciences Appliquées de Fès (ENSA Fès) pour la qualité de la formation dispensée, leur engagement et leur accompagnement tout au long de mon parcours académique, qui ont contribué à forger mes compétences et à enrichir mes connaissances.

Résumé

Ce projet de fin d'études s'inscrit dans le contexte stratégique de la mise en œuvre de la norme ISO 27001 au sein des organisations. Il a pour objectif principal la conception et le développement d'une plateforme SaaS multi-sociétés, innovante et centralisée, dédiée à la gestion, au pilotage et au suivi d'un Système de Management de la Sécurité de l'Information (SMSI) conforme à la norme ISO 27001:2022. Outre le suivi de l'ISO 27001, cette solution met à disposition un outil complet intégrant plusieurs modules tels que le dashboard, le cycle PDCA, la gestion des clauses et contrôles de l'Annexe A, la gestion documentaire, la gestion des actifs, la planification et le suivi des audits, la sensibilisation et la gestion des risques selon la méthodologie EBIOS RM. L'intégration de cette méthodologie permet une identification, une analyse et un traitement systématiques des risques de sécurité de l'information à travers ses 5 ateliers de travail, en parfaite complémentarité avec la norme ISO 27001. Les résultats obtenus mettent en évidence une solution de gouvernance robuste, cohérente et évolutive, capable d'accompagner efficacement les organisations dans la maîtrise de leur sécurité de l'information, l'amélioration continue de leur SMSI et le suivi rigoureux de leur conformité réglementaire.

Mots clés : SMSI, ISO 27001:2022, EBIOS RM, SaaS, Multi-sociétés, PDCA, Gestion des risques, Annexe A, Audit, Gestion documentaire, Conformité.

Summary

This end-of-study project is part of the strategic context of implementing the ISO 27001 standard within organizations. Its main objective is the design and development of an innovative, centralized, multi-tenant SaaS platform dedicated to the management, governance, and monitoring of an Information Security Management System (ISMS) compliant with ISO 27001:2022. Beyond ISO 27001 compliance tracking, this solution provides a comprehensive tool integrating several modules, including a dashboard, the PDCA cycle, management of clauses and Annex A controls, document management, asset management, audit planning and monitoring, awareness management, and risk management based on the EBIOS RM methodology. The integration of this methodology enables systematic identification, analysis, and treatment of information security risks through its five workshops, in full alignment with the ISO 27001 standard. The results highlight a robust, consistent, and scalable governance solution, capable of effectively supporting organizations in controlling their information security, continuously improving their ISMS, and ensuring rigorous monitoring of regulatory compliance.

Key Words : ISMS, ISO 27001:2022, EBIOS RM, SaaS, Multi-tenant, PDCA, Risk Management, Annex A, Audit, Document Management, Compliance.

ملخص

يندرج هذا المشروع في الإطار الاستراتيجي لتطبيق معيار الأيزو ٢٧٠٠١ داخل المؤسسات، ويهدف إلى تصميم وتطوير منصة مركزية مبتكرة من البرمجيات كخدمة متعددة المؤسسات، مخصصة لإدارة وتسيير ومتابعة نظام إدارة أمن المعلومات المتوافق مع معيار الأيزو ٢٧٠٠١ لسنة ٢٠٢٢. يضم عدة وحدات، من بينها لوحة القيادة، ودورة التحسين المستمر (عضثا)، وإدارة البنود وضوابط الملحق أ، وإدارة الوثائق، وإدارة الأصول، وتخطيط ومتابعة عمليات التدقيق، وإدارة التوعية، إضافة إلى إدارة المخاطر وفق منهجية إيبوس لإدارة المخاطر. ويساهم دمج هذه المنهجية في تحديد وتحليل ومعالجة مخاطر أمن المعلومات بشكل منهجي من خلال ورش العمل الخمس الخاصة بها، بما يتماشى مع متطلبات معيار الأيزو ٢٧٠٠١. **الحوكمة**، حيث يتيح للمؤسسات تعزيز التحكم في أمن معلوماتها، وتحسين نظام إدارة أمن المعلومات بشكل مستمر، وضمان متابعة دقيقة للامتثال للمتطلبات التنظيمية.

الكلمات المفتاحية نظام إدارة أمن المعلومات، المعيار الدولي ٢٧٠٠١:٢٠٢٢، منهجية إيبوس لإدارة المخاطر، البرمجيات كخدمة، متعدد الكيانات، دورة التحسين المستمر، إدارة المخاطر، الملحق ألف، التدقيق، إدارة الوثائق، الامتثال.

Liste des figures

1.1	Logo Alexsys Solutions [1]	3
1.2	chiffre clé d'Alexsys Solutions [3]	4
1.3	domaine d'expertise d'Alexsys Solutions [3]	4
1.4	clients d'Alexsys Solutions [3]	5
1.5	Méthodologie et outils de développement	6
1.6	équipe du projet	11
1.7	Processus du développement SCRUM [4]	12
1.8	Logo Jira	15
1.9	Sprint Backlog	16
1.10	Tableau de suivi	17
1.11	Diagramme de Gantt	17

Liste des tableaux

1.1	choix techniques	10
2.1	Étude de l'existant des solutions SMSI	20
3.1	Table 1	30

Liste des codes

Table des matières

Dédicace	i
Acknowledgments	ii
Résumé	iii
Summary	iv
Arabic Abstract	v
Liste des figures	vi
Liste des tableaux	vii
Liste des codes	viii
Table des matières	xii
Acknowledgments	1
1 Contexte général du projet	2
1.1 Présentation de l'entreprise d'accueil Alexsys Solutions	3
1.1.1 ALEXSYS SOLUTIONS	3
1.1.2 Secteurs d'activité	3
1.1.3 Chiffres clé de l'entreprise	4
1.1.4 Domaines d'expertise technologiques	4
1.1.5 Principaux clients de l'entreprise	5
1.1.6 Méthodologie et outils de développement	5
1.2 Présentation du projet	6

1.2.1	Cadre du projet	6
1.2.2	Problématique	7
1.2.3	Objectifs du projet	8
1.2.3.1	Objectifs fonctionnels	8
1.2.4	Objectifs fonctionnels	8
1.2.4.1	Objectifs techniques	9
1.2.4.2	Objectifs pédagogiques	10
1.3	Démarche du projet	11
1.3.1	Présentation de l'équipe du projet	11
1.3.2	Méthodologie de travail	11
1.3.2.1	Les rôles et responsabilités	13
1.3.2.2	Les artefacts du cadre Scrum	13
1.3.2.3	Le cycle de vie d'un Sprint	14
1.3.2.4	Justification du choix méthodologique	15
1.3.3	Gestion Agile du projet avec Jira	15
1.3.3.1	Présentation de l'outil	15
1.3.3.2	Organisation du travail : le Backlog	15
1.3.3.3	Suivi de l'itération : le Sprint Board	16
1.3.4	Diagramme de Gantt	17
2	Analyse et spécification des besoins	19
2.1	Étude de l'existant et de faisabilité	20
2.1.1	Étude d'existant	20
2.1.2	Étude de faisabilité	21
2.1.2.1	Faisabilité technique	21
2.1.2.2	Faisabilité organisationnelle	21
2.1.2.3	Faisabilité économique	22
2.2	Spécification des besoins fonctionnels et non fonctionnels	22
2.2.1	Besoins fonctionnels	22
2.2.2	Besoins non fonctionnels	25
2.3	Rédaction du cahier des charges	26
2.3.1	Spécifications fonctionnelles	26
2.3.2	Spécifications techniques	27

3	Conception de la solution	29
3.1	Section1	30
3.1.1	Subsection1	30
3.1.2	Subsection2	30
3.1.2.1	Subsubsection1	30
3.1.2.2	Subsubsection2	30
3.1.2.2.1	Paragraph a	30
3.1.2.2.2	Paragraph b	30
3.2	Section2	30
3.2.1	Subsection1	30
3.2.2	Subsection2	30
3.2.2.1	Subsubsection1	30
3.2.2.2	Subsubsection2	30
3.2.2.2.1	Paragraph a	30
3.2.2.2.2	Paragraph b	30
4	Tests, Déploiement et résultats	32
4.1	Section1	33
4.1.1	Subsection1	33
4.1.2	Subsection2	33
4.1.2.1	Subsubsection1	33
4.1.2.2	Subsubsection2	33
4.1.2.2.1	Paragraph a	33
4.1.2.2.2	Paragraph b	33
4.2	Section2	33
4.2.1	Subsection1	33
4.2.2	Subsection2	33
4.2.2.1	Subsubsection1	33
4.2.2.2	Subsubsection2	33
4.2.2.2.1	Paragraph a	33
4.2.2.2.2	Paragraph b	33
	Conclusion générale et perspectives	35

A	Glossaire	36
B	Acronymes	37
	Bibliographie	39

Introduction générale

Dans un environnement numérique marqué par l'accélération des cybermenaces, la multiplication des exigences réglementaires et la complexification des systèmes d'information, la maîtrise de la sécurité des données est devenue un enjeu stratégique central pour les organisations de toutes tailles. La norme ISO/IEC 27001:2022, référence internationale en matière de Système de Management de la Sécurité de l'Information (SMSI), impose désormais un cadre normatif plus exigeant. Si cette évolution renforce la robustesse des dispositifs de gouvernance, elle accroît également la complexité opérationnelle et le besoin d'outils adaptés pour piloter la conformité de manière continue et traçable.

Pourtant, force est de constater que de nombreuses organisations, en particulier les petites et moyennes entreprises, ne disposent pas de solutions adaptées à leurs moyens. Elles se trouvent souvent contraintes d'utiliser des outils génériques ou de recourir à des plateformes propriétaires coûteuses, rigides et difficilement personnalisables. Ces approches engendrent une absence de traçabilité, une difficulté à produire des indicateurs de performance fiables et une collaboration inefficace entre les parties prenantes.

Ce projet de fin d'études, réalisé au sein de la société Alexsys Solutions, vise à répondre à cette problématique par le développement d'une plateforme dédiée au pilotage de la conformité ISO 27001:2022. L'objectif est de fournir une plateforme centralisée, permettant de couvrir l'ensemble du cycle de vie de la sécurité de l'information, depuis l'analyse du contexte et des risques (phase PLAN) jusqu'à l'amélioration continue (ACT), en passant par la mise en œuvre des contrôles (DO) et les audits (CHECK).

Ainsi, ce rapport s'articule autour de **Plusieurs** chapitres. Après avoir posé le contexte général et la problématique, la méthodologie adoptée (**Chapitre I**), nous détaillerons l'étude de l'existant, la faisabilité et l'analyse des besoins. (Chapitre II). Suivie par la phase de conception (Chapitre III). Viendront ensuite la présentation des choix d'implémentation et de la réalisation, test et déploiement (Chapitre IV). Enfin, une conclusion et perspectives ouvrira la réflexion sur les évolutions possibles.

L'ambition de ce travail est de démontrer qu'il est possible de concilier exigence normative, innovation technologique et accessibilité pour répondre aux véritables besoins des organisations engagées dans une démarche de certification ou de maintien de leur SMSI.

Chapitre 1

Contexte général du projet

Introduction

Ce chapitre positionne mon projet de fin d'études dans son cadre organisationnel et contextuel. Il débute par une présentation de l'organisme d'accueil, ALEXSYS SOLUTIONS, puis expose la problématique à l'origine de ce projet ainsi que les objectifs poursuivis. Enfin, il décrit la méthodologie mise en œuvre pour assurer la réussite du projet.



1.1 Présentation de l'entreprise d'accueil Alexsys Solutions

Cette première section est consacré à la présentation de la société ALEXSYS SOLUTIONS, une entité significative dans le secteur de services et conseils en informatique. Nous allons en esquisser l'identité fondamentale et la position qu'il occupe actuellement, ses activités principales, son chiffre d'affaires et sa clientèle. 

1.1.1 ALEXSYS SOLUTIONS



Figure 1.1: Logo Alexsys Solutions [1]

Alexsys Solutions a été fondée le 28 janvier 2020 à Casablanca par Abdellatif Tarhine. Il s'agit d'une Société à Responsabilité Limitée (SARL) à associé unique, avec un capital social fixé à 100 000,00 DHS. L'entreprise, spécialisée dans l'ingénierie et le conseil informatique, compte entre 51 et 200 employés. Son siège social est situé au numéro 37, Allée des Eucalyptus, à Aïn Sebâa, Casablanca, au Maroc. [2]

1.1.2 Secteurs d'activité

ALEXSYS SOLUTIONS est une entreprise spécialisée dans les technologies de l'information et les services numériques. Elle se positionne comme un acteur majeur du conseil en technologies innovantes et du management des systèmes d'information, accompagnant ses clients dans leur transformation digitale. L'entreprise propose une gamme complète de services technologiques qui couvre notamment: Audit des systèmes d'information et stratégie digitale, Gestion et modernisation des infrastructures IT (Cloud, sécurité, etc.), Data Analytics & Intelligence Artificielle pour exploiter les données à forte valeur ajoutée, Internet des Objets (IoT) et solutions Smart City, Développement logiciel spécifique et intégration de systèmes, Automatisation intelligente des processus (IPA) et solutions métiers digitales. ALEXSYS développe également des plateformes SaaS et des solutions métiers utilisées dans des contextes variés comme l'éducation (plateforme Educ-AI), la gestion des déchets (Wacomos), la gestion d'activités

quotidiennes (Trepho), l'optimisation de la qualité et conformité (Optima), l'intégration SAP (MicSap), ou encore la reconnaissance intelligente des plaques (Smart Match). Ainsi, l'entreprise agit au carrefour de l'innovation technologique, de la transformation digitale et de l'amélioration des processus métiers, en répondant aux besoins des organisations publiques et privées. [3]

1.1.3 Chiffres clé de l'entreprise

Les chiffres ci-dessous permettent de présenter de manière synthétique les caractéristiques essentielles de l'entreprise, notamment son chiffre d'affaire, son Portefeuille client et le nombre de ces employés.



Figure 1.2: chiffre clé d'Alexsys Solutions [3]

1.1.4 Domaines d'expertise technologiques

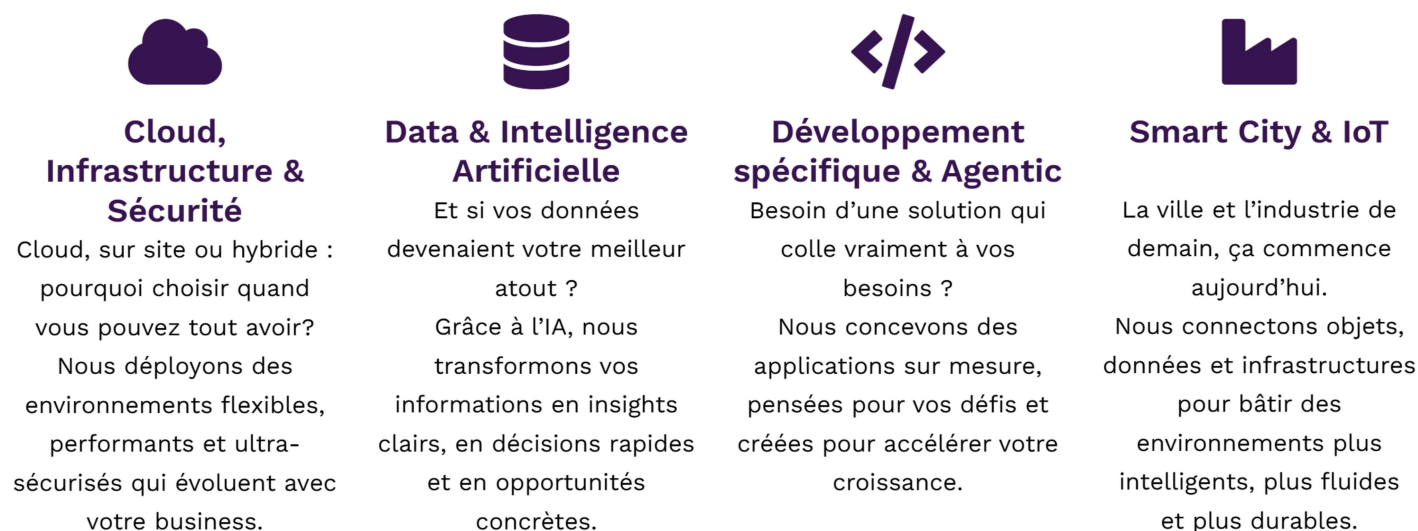


Figure 1.3: domaine d'expertise d'Alexsys Solutions [3]

1.1.5 Principaux clients de l'entreprise

Alexsys Solutions s'appuie sur un portefeuille de clients diversifié et solide, composé d'acteurs majeurs issus de secteurs variés. Cette base clients témoigne de la confiance accordée à l'entreprise et de sa capacité à répondre aux besoins complexes de structures publiques comme privées au Maroc.



Figure 1.4: clients d'Alexsys Solutions [3]

1.1.6 Méthodologie et outils de développement

Alexsys Solutions s'appuie sur un ensemble de méthodologies et d'outils technologiques modernes afin d'accompagner la réalisation et la réussite des projets informatiques. Ces approches couvrent différents aspects, notamment la gestion de projet, le développement logiciel, l'intégration continue ainsi que l'architecture des systèmes. Elles permettent d'assurer une meilleure organisation du travail, d'optimiser les processus de développement et de garantir des solutions performantes, sécurisées et adaptées aux besoins des clients.



Figure 1.5: Méthodologie et outils de développement

Alexsys Solutions adopte une méthodologie structurée et agile pour la mise en place des systèmes d'information. L'entreprise dispose d'une plateforme complète combinant infrastructures techniques, outils collaboratifs et standards architecturaux modernes



1.2 Présentation du projet

1.2.1 Cadre du projet

La norme ISO/IEC 27001:2022 constitue la référence internationale en matière de mise en œuvre d'un Système de Management de la Sécurité de l'Information (SMSI). Sa révision publiée en 2022 a introduit 11 nouveaux contrôles et restructuré l'Annexe A autour de quatre catégories thématiques: organisationnels, personnels, physiques et technologiques portant le total à 93 contrôles de sécurité.

Dans ce contexte normatif en constante évolution, les organisations sont confrontées à une complexité croissante liée à la gestion de la sécurité de l'information. La multiplicité des exigences, la gestion documentaire, le suivi des audits, la traçabilité des preuves de conformité ainsi que la gestion des risques représentent des défis importants, en particulier pour les structures multi-sociétés ou les groupes disposant de plusieurs entités.

Les enjeux sont à la fois stratégiques et opérationnels. D'une part, il s'agit d'assurer l'obtention et le maintien de la certification ISO 27001. D'autre part, les organisations doivent garantir une gouvernance efficace, continue et auditable de leur système de sécurité de l'information, tout en s'inscrivant dans une logique d'amélioration continue basée sur le cycle PDCA.

C'est dans ce cadre que s'inscrit le présent projet de fin d'études, qui vise la conception et le développement d'une plateforme SaaS multi-sociétés dédiée à la gestion, au pilotage et au suivi d'un SMSI conforme à la norme ISO 27001:2022. Cette solution propose une approche centralisée intégrant plusieurs fonctionnalités clés.

La solution est destinée à être utilisée à la fois en interne par Alexsys Solutions pour piloter sa propre conformité, mais également déployée chez ses clients dans le cadre de missions d'accompagnement à la certification ISO 27001. L'architecture multi-tenant de la plateforme permet de supporter cette double vocation : usage interne et offre de service externalisée.

1.2.2 Problématique

Malgré l'importance croissante de la sécurité de l'information, la mise en œuvre et le pilotage d'un Système de Management de la Sécurité de l'Information (SMSI) conforme à la norme ISO/IEC 27001:2022 demeurent complexes pour de nombreuses organisations.

En effet, les entreprises sont confrontées à plusieurs difficultés majeures. La gestion des exigences normatives repose souvent sur des outils dispersés (fichiers Excel, documents Word, emails), rendant difficile la centralisation des informations et la traçabilité des actions. Le suivi des contrôles de l'Annexe A, la gestion des risques, la planification des audits ainsi que le traitement des non-conformités manquent souvent de structuration et d'automatisation.

De plus, l'absence d'une vision globale et en temps réel de l'état de conformité complique la prise de décision et le pilotage stratégique. Cette problématique est encore plus accentuée dans les environnements où la gestion simultanée de périmètre de conformité devient lourde et difficile à coordonner.

Par ailleurs, les solutions existantes sur le marché sont soit coûteuses, soit peu adaptées aux besoins spécifiques des organisations, notamment en termes de flexibilité, de personnalisation et d'intégration des méthodologies de gestion des risques telles que EBIOS RM.

Dans ce contexte, la problématique principale de ce projet peut être formulée comme suit :

Comment concevoir et développer une plateforme SaaS exploitable aussi bien en interne qu'en tant qu'offre de service externalisée, centralisée et évolutive, permettant d'assurer une gestion efficace, automatisée et conforme d'un SMSI selon la norme ISO 27001:2022, tout en intégrant une approche

structurée de gestion des risques basée sur la méthodologie EBIOS RM ?

1.2.3 Objectifs du projet

~~1.2.3.1 Objectifs fonctionnels~~

Le projet **ISMS Manager** poursuit un ensemble d'objectifs fonctionnels, techniques et stratégiques visant à répondre aux insuffisances identifiées lors de l'étude de l'existant et à apporter une solution concrète à la problématique posée.

1.2.4 Objectifs fonctionnels

Les objectifs fonctionnels définissent les capacités opérationnelles que la plateforme doit offrir à ses utilisateurs afin de couvrir l'intégralité du cycle de vie d'un SMSI conforme à la norme ISO 27001.

Centraliser la gestion du SMSI

L'objectif premier de la plateforme est de regrouper en un seul outil l'ensemble des processus liés au management de la sécurité de l'information : gestion des actifs, des risques, des contrôles, des audits, des incidents et de la conformité. Cette centralisation vise à éliminer la dispersion des informations entre plusieurs outils hétérogènes et à offrir une vision globale et cohérente du SMSI à tous les acteurs concernés.

Automatiser les processus SMSI

La plateforme doit réduire la charge administrative liée à la gestion manuelle du SMSI en automatisant les tâches récurrentes. Cette automatisation permet de minimiser les erreurs humaines et d'améliorer la réactivité de l'organisation face aux risques.

Assurer la conformité à la norme ISO 27001

La plateforme doit permettre aux organisations de suivre et de démontrer leur conformité aux exigences de la norme ISO 27001, clause par clause. Elle doit offrir la possibilité d'associer des preuves documentaires à chaque contrôle évalué, de consigner l'historique des évaluations, facilitant ainsi les démarches de certification et les audits externes.

Mettre en œuvre la méthode EBIOS Risk Manager

La plateforme doit intégrer nativement la méthode EBIOS RM, reconnue par l'ANSSI, pour structurer l'analyse des risques de manière rigoureuse. Elle doit permettre l'identification des biens essentiels, la modélisation des scénarios de menace, la cotation des risques selon les axes impact et vraisemblance, ainsi que la visualisation des risques sous forme de heatmap et le suivi des plans de traitement associés.

Piloter les audits

Le système doit permettre la planification d'un programme annuel d'audits, la traçabilité des non-conformités, des opportunités d'amélioration et des actions correctives. Les rapports d'audit doivent être générables et exportables aux formats PDF et Word.

Gérer les incidents de sécurité

La plateforme doit offrir un module complet de gestion des incidents permettant de déclarer, classer, suivre et clôturer les événements de sécurité affectant les actifs informationnels.

Piloter l'amélioration continue via le cycle PDCA

La plateforme doit intégrer un module de pilotage des actions d'amélioration continue selon le cycle Plan-Do-Check-Act. Un responsable SMSI doit pouvoir créer, affecter, suivre et clôturer des actions correctives ou préventives, avec des indicateurs d'avancement et des alertes automatiques sur les échéances dépassées.

Fournir un tableau de bord KPI consolidé

La plateforme doit proposer un dashboard centralisé offrant une vue synthétique et en temps réel des indicateurs clés de performance du SMSI.

Gérer plusieurs sociétés de manière isolée

La plateforme doit supporter une architecture multi-tenant permettant à un administrateur de gérer plusieurs entités ou filiales de manière totalement isolée. L'isolation des données entre tenants doit être garantie à tous les niveaux de l'application.

Contrôler les accès par rôles et permissions

Le système doit mettre en œuvre un mécanisme de contrôle d'accès basé sur les rôles (RBAC) finement paramétrable, permettant de définir des permissions spécifiques par module, par action et par société. Les rôles métier prévus incluent : Administrateur, RSSI, Responsable SMSI, Analyste Risque, Auditeur, Valideur et Utilisateur standard.

1.2.4.1 Objectifs techniques

Sur le plan technique, le projet vise à mettre en œuvre une architecture moderne, robuste et évolutive, articulée autour des choix suivants :

Table 1.1: choix techniques

Couche	Technologie choisie	Justification
Frontend	React.js 18+	SPA moderne, composants réutilisables, hooks, React Router v6
Backend	.NET 8 / C# (Clean Architecture + CQRS)	Séparation des préoccupations, maintenabilité, scalabilité
Base de données	Azure SQL Server + EF Core 8	ORM robuste, migrations automatisées, support multi-tenant
Authentification	JWT + RBAC (ASP.NET Core Identity)	stateless sécurisée, gestion des rôles
Hébergement	Microsoft Azure App	CI/CD, scalabilité automatique
Stockage fichiers	Azure Blob Storage	Upload de preuves, logos et documents PDF (25 Mo max)

1.2.4.2 Objectifs pédagogiques

Au-delà des livrables fonctionnels et techniques, ce projet de fin d'études poursuit des objectifs de montée en compétences dans les domaines suivants :

- Maîtriser l'architecture Clean Architecture appliquée à une application métier complexe et à fort volume de données.
- Mettre en œuvre le pattern CQRS (Commands / Queries / Handlers) avec la bibliothèque MediatR dans un contexte réel.
- Développer une SPA React.js complète, communiquant avec une API REST .NET via Axios avec gestion du JWT.
- Comprendre et appliquer les exigences fonctionnelles et réglementaires de la norme ISO 27001:2022 dans un contexte industriel.
- Concevoir et livrer une solution complète, de la spécification jusqu'à la mise en production sur Microsoft Azure.

1.3 Démarche du projet

1.3.1 Présentation de l'équipe du projet

L'organisation de notre équipe repose sur une synergie entre l'expertise technique et le pilotage stratégique. Elle s'articule autour de trois développeuses Full Stack et de deux fonctions clés indispensables au cadre méthodologique : le Product Owner et le Scrum Master.

Cette répartition précise des responsabilités garantit une collaboration fluide et constitue le socle nécessaire pour assurer l'efficacité du cycle de développement et la réussite finale du projet.

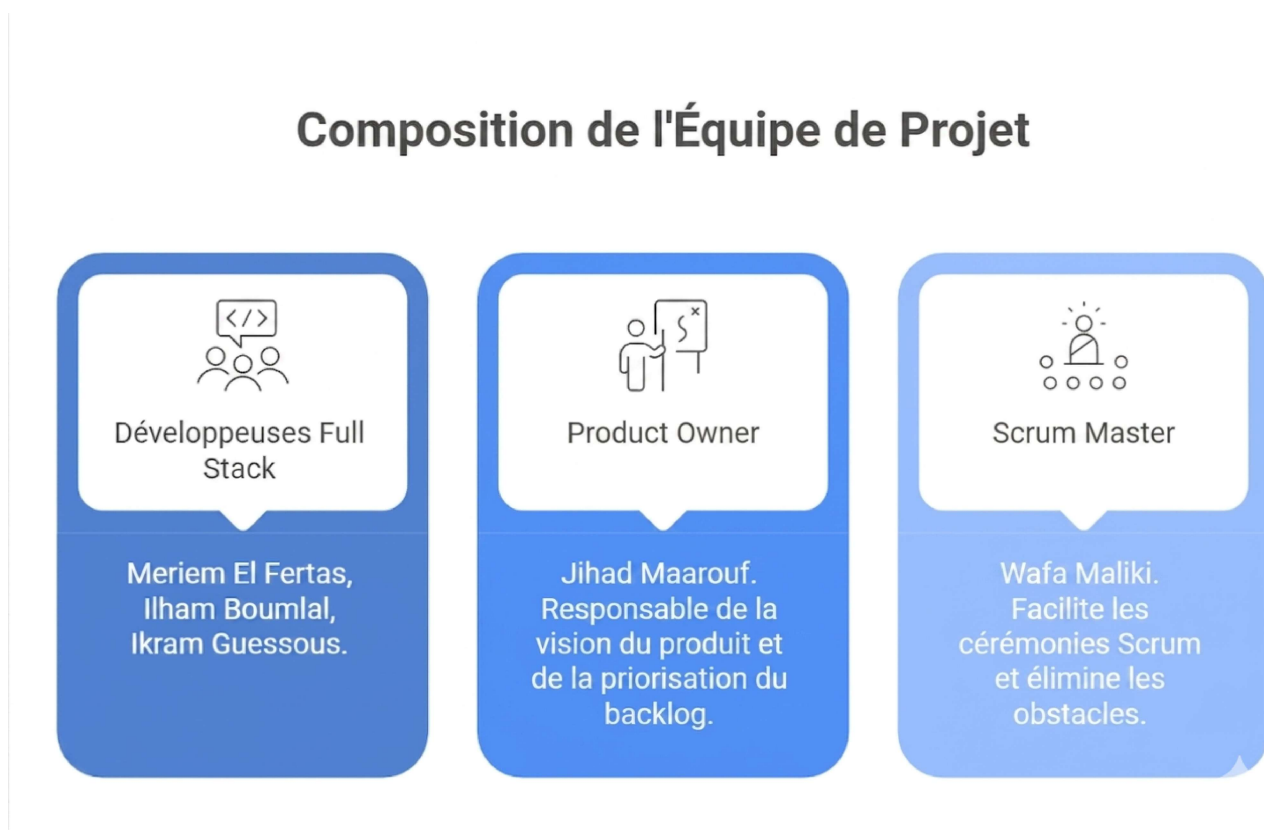


Figure 1.6: équipe du projet

1.3.2 Méthodologie de travail

La conduite de tout projet d'ingénierie logicielle requiert l'adoption d'une méthodologie de développement rigoureuse, capable de garantir à la fois la maîtrise des délais, la qualité des livrables et la traçabilité des décisions techniques prises tout au long du cycle de vie du projet. Dans ce cadre, nous avons retenu la méthodologie Agile Scrum comme cadre méthodologique de référence pour la gestion et le pilotage de ce projet de fin d'études. Ce choix repose sur la nature itérative et incrémentale des besoins identifiés en

amont, la complexité technique des fonctionnalités à développer, ainsi que la nécessité d'une validation continue des livrables par rapport aux exigences fonctionnelles et non fonctionnelles définies.

PROCESSUS SCRUM

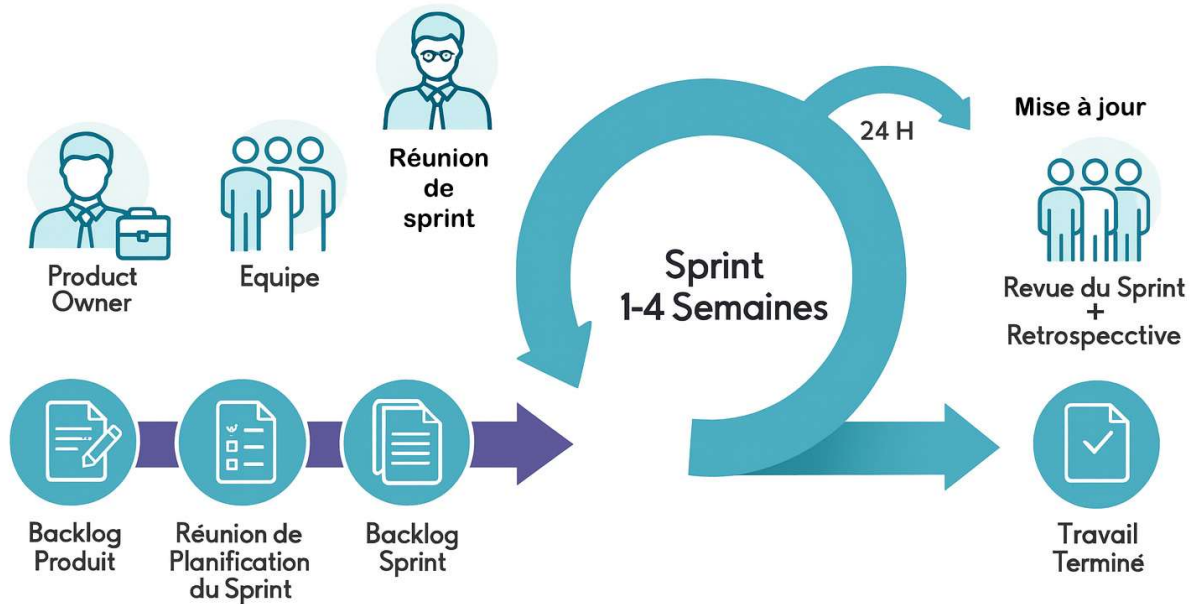


Figure 1.7: Processus du développement SCRUM [4]

Scrum est un cadre de travail empirique issu du mouvement Agile, formalisé par le Scrum Guide et fondé sur trois piliers épistémologiques fondamentaux : la transparence, l'inspection et l'adaptation. Contrairement aux approches prédictives classiques telles que le cycle en V ou le modèle en cascade, Scrum ne cherche pas à figer l'ensemble des exigences en début de projet, mais à livrer de la valeur de manière continue et contrôlée à travers des itérations courtes et régulières appelées Sprints. Cette capacité à intégrer le changement de manière structurée constitue un avantage décisif dans les projets de développement logiciel, où les exigences évoluent fréquemment en fonction des retours utilisateurs et des contraintes techniques découvertes en cours de réalisation. La transparence impose que l'ensemble des informations relatives à l'état du projet, aux tâches en cours et aux obstacles rencontrés soient accessibles et compréhensibles par tous les acteurs impliqués. L'inspection consiste en un examen régulier et systématique des artefacts produits et de la progression du travail, afin de détecter tout écart par rapport aux objectifs fixés. L'adaptation, enfin, est le mécanisme correctif qui permet d'ajuster le plan d'action en réponse aux observations issues de l'inspection, minimisant ainsi les risques de dérive technique ou fonctionnelle.

1.3.2.1 Les rôles et responsabilités

L'organisation Scrum repose sur une structure humaine légère mais clairement définie, composée de trois rôles aux responsabilités complémentaires et non hiérarchiques.

Le **Product Owner** assume la responsabilité de maximiser la valeur du produit livré. Il est le garant de la vision fonctionnelle du système, et assure la gestion du Backlog Produit, un référentiel dynamique et ordonné de l'ensemble des exigences fonctionnelles, techniques et des user stories du projet. Il est seul habilité à définir les priorités de développement, en s'appuyant sur des critères de valeur métier, de complexité technique et de dépendances entre les fonctionnalités.

L'**Équipe de développement** est un groupe pluridisciplinaire, auto-organisé et collectivement responsable de la conception, du développement, des tests et de la livraison des incréments logiciels. Dans un contexte d'ingénierie, cette équipe réunit les compétences nécessaires pour couvrir l'ensemble du cycle de réalisation technique, de l'architecture système jusqu'aux phases de validation et de déploiement. L'auto-organisation de l'équipe signifie qu'elle décide elle-même de la manière dont elle distribue et réalise les tâches, sans dépendre d'une supervision externe pour les choix d'implémentation.

Le **Scrum Master** occupe un rôle transverse de facilitation et de coaching. Il est le garant de la bonne application du cadre Scrum au sein de l'équipe, identifie et lève les obstacles organisationnels ou techniques qui freinent la productivité, et veille à ce que les cérémonies Scrum se déroulent dans les conditions optimales. Il n'est pas un chef de projet au sens traditionnel du terme, mais un servant-leader au service de l'équipe et du processus.

1.3.2.2 Les artefacts du cadre Scrum

Scrum s'appuie sur trois artefacts principaux, conçus pour assurer la transparence et permettre un suivi précis de l'avancement du projet. Le **Backlog Produit** constitue la source unique de vérité pour l'ensemble des fonctionnalités à développer. Chaque élément du Backlog, appelé **User Story**, est décrit selon un format standardisé précisant l'acteur concerné, l'action souhaitée et la valeur attendue. Ces éléments sont estimés en termes de complexité relative, généralement à l'aide de la technique du Planning Poker, et ordonnés par le **Product Owner** selon leur priorité stratégique.

Le **Backlog Sprint** est un sous-ensemble du Backlog Produit, constitué des User Stories sélectionnées par l'équipe pour être réalisées au cours d'un Sprint donné. Il représente l'engagement formel de l'équipe pour l'itération en cours et inclut également le plan technique détaillant comment chaque fonctionnalité sera conçue et implémentée. Le Backlog Sprint reste stable pendant toute la durée du Sprint, sauf circonstances exceptionnelles justifiant une révision de périmètre en accord avec le Product Owner.

L'**Incrément** est le résultat concret et livrable de chaque Sprint. Il correspond à l'ensemble des fonctionnalités complétées durant l'itération, intégrées au produit existant et satisfaisant la Definition of Done, c'est-à-dire un ensemble de critères de complétude définis collectivement par l'équipe, incluant notamment la conformité fonctionnelle, la couverture des tests, la revue de code et la documentation associée.

1.3.2.3 Le cycle de vie d'un Sprint

Le Sprint constitue l'unité temporelle fondamentale du processus Scrum. Sa durée, fixée entre une et quatre semaines, est définie en début de projet et maintenue constante tout au long du développement afin d'instaurer un rythme de travail régulier et prévisible. Dans le cadre de notre projet, nous avons opté pour des Sprints d'une durée fixe, permettant de livrer des fonctionnalités testables et validables de manière périodique. Chaque Sprint s'articule autour de quatre cérémonies formelles, chacune répondant à un objectif précis dans le cycle de développement.

La **Réunion de Planification du Sprint** marque le point d'entrée de chaque itération. Elle réunit l'ensemble de l'équipe Scrum autour d'un double objectif : définir l'objectif du Sprint, c'est-à-dire la valeur que l'itération doit apporter, et sélectionner les User Stories du Backlog Produit que l'équipe s'engage à réaliser, en tenant compte de sa vélocité et de la capacité disponible. À l'issue de cette réunion, le Backlog Sprint est constitué et les tâches techniques sont décomposées et assignées.

La **Mêlée Quotidienne**, ou Daily Scrum, est une réunion de synchronisation de courte durée, tenue chaque jour à heure fixe, au cours de laquelle chaque membre de l'équipe rend compte de l'avancement de ses tâches, signale les blocages éventuels et coordonne ses activités avec le reste de l'équipe. Cette cérémonie constitue un mécanisme de contrôle continu de l'avancement du Sprint et permet une détection précoce des risques de non-atteinte des objectifs fixés.

La **Revue du Sprint** constitue le point de contrôle fonctionnel du Sprint. Elle prend la forme d'une démonstration des fonctionnalités développées devant les parties prenantes, permettant de valider la conformité des livrables par rapport aux exigences initiales, de recueillir des retours d'expérience et de mettre à jour le Backlog Produit en conséquence. Elle garantit ainsi un alignement continu entre les réalisations techniques de l'équipe et les attentes fonctionnelles du projet.

La **Rétrospective de Sprint clôture** le cycle de chaque itération. Centrée sur le processus de travail plutôt que sur le produit, elle offre à l'équipe un espace de réflexion structuré pour analyser son fonctionnement interne, identifier les points d'amélioration dans les pratiques de développement, de communication et de collaboration, et définir un plan d'action opérationnel pour l'itération suivante.

La Rétrospective est le principal vecteur d'amélioration continue au sein du cadre Scrum, et contribue à l'élévation progressive de la maturité technique et organisationnelle de l'équipe.

1.3.2.4 Justification du choix méthodologique

Le choix de Scrum comme méthodologie de référence pour ce projet de fin d'études d'ingénieur se justifie par plusieurs arguments techniques et organisationnels. Premièrement, la décomposition du périmètre fonctionnel en incréments livrables permet une validation progressive des choix d'architecture et de conception, réduisant significativement le risque de non-conformité du produit final. Deuxièmement, les mécanismes d'inspection et d'adaptation intégrés dans le cadre Scrum offrent une résilience naturelle face aux imprévus techniques, fréquents dans tout projet d'ingénierie logicielle d'envergure. Troisièmement, la transparence inhérente au processus facilite le suivi et l'évaluation du projet par l'encadrant académique, en fournissant une visibilité claire et documentée sur l'état d'avancement à chaque jalon du développement. Enfin, l'adoption de Scrum constitue en elle-même une préparation pertinente à l'environnement professionnel de l'ingénieur logiciel moderne, où ces pratiques Agile sont aujourd'hui largement répandues et reconnues comme standard industriel.

1.3.3 Gestion Agile du projet avec Jira

1.3.3.1 Présentation de l'outil

Dans le cadre de ce projet, la gestion et le suivi des activités ont été assurés à l'aide de Jira, une plateforme de gestion de projet développée par Atlassian. Largement adoptée dans les environnements de développement logiciel, elle permet de structurer le travail en unités claires et traçables, de centraliser la communication autour des tâches et d'offrir une visibilité en temps réel sur l'avancement du projet.



Figure 1.8: Logo Jira

1.3.3.2 Organisation du travail : le Backlog

L'ensemble des fonctionnalités à développer a été découpé en user stories, chacune représentant un besoin fonctionnel exprimé du point de vue de l'utilisateur. Ces user stories sont regroupées dans le

Product Backlog, référentiel central et priorisé de tout le travail planifié. À chaque début de sprint, une sélection de ces user stories est extraite du backlog et intégrée au Sprint Backlog, définissant ainsi le périmètre de travail de l'itération.

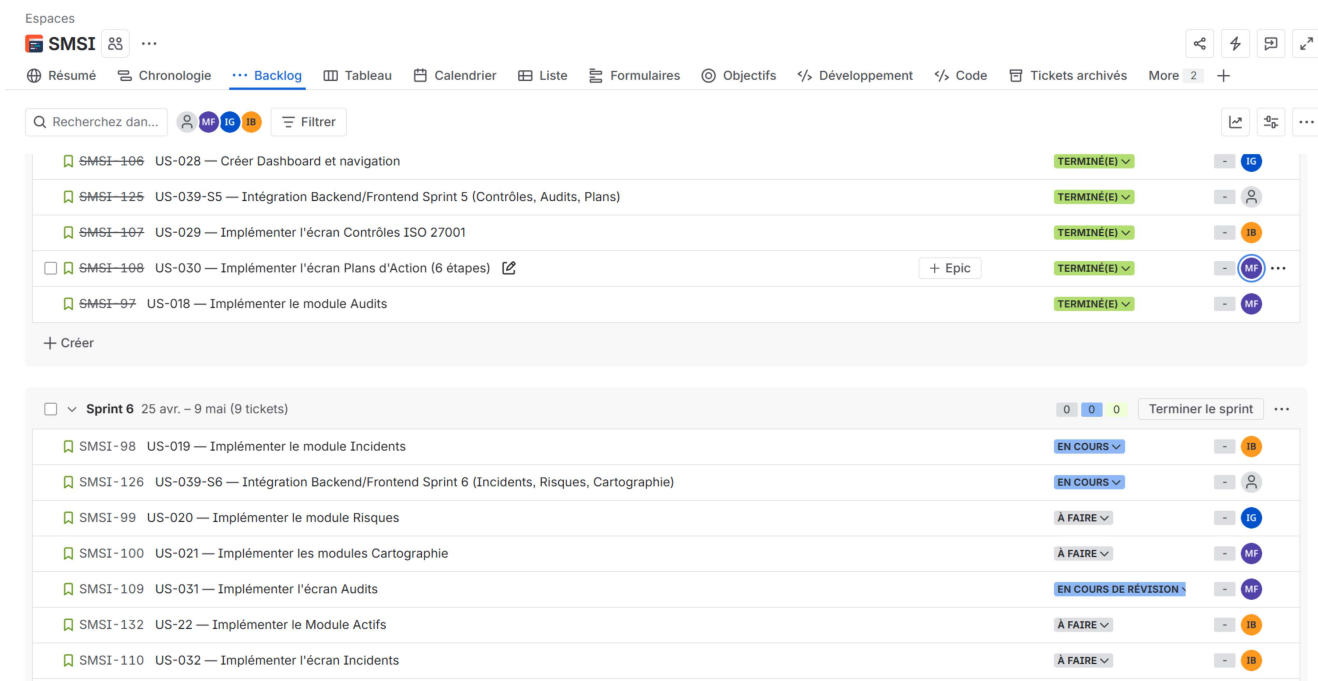


Figure 1.9: Sprint Backlog

On observe la structuration des user stories par sprint, accompagnées de leur état d'avancement : À faire, En cours, En cours de révision, et Terminé. Cette vue permet à l'équipe de planifier les itérations et de maintenir une vision globale du projet.

1.3.3.3 Suivi de l'itération : le Sprint Board

Pour piloter l'avancement au quotidien durant chaque sprint, Jira propose une vue Tableau correspondant au Sprint Board Scrum. Chaque user story y est représentée sous forme de carte, déplacée d'une colonne à l'autre au fur et à mesure de sa progression. La figure suivante présente le Sprint Board du projet en cours d'itération :

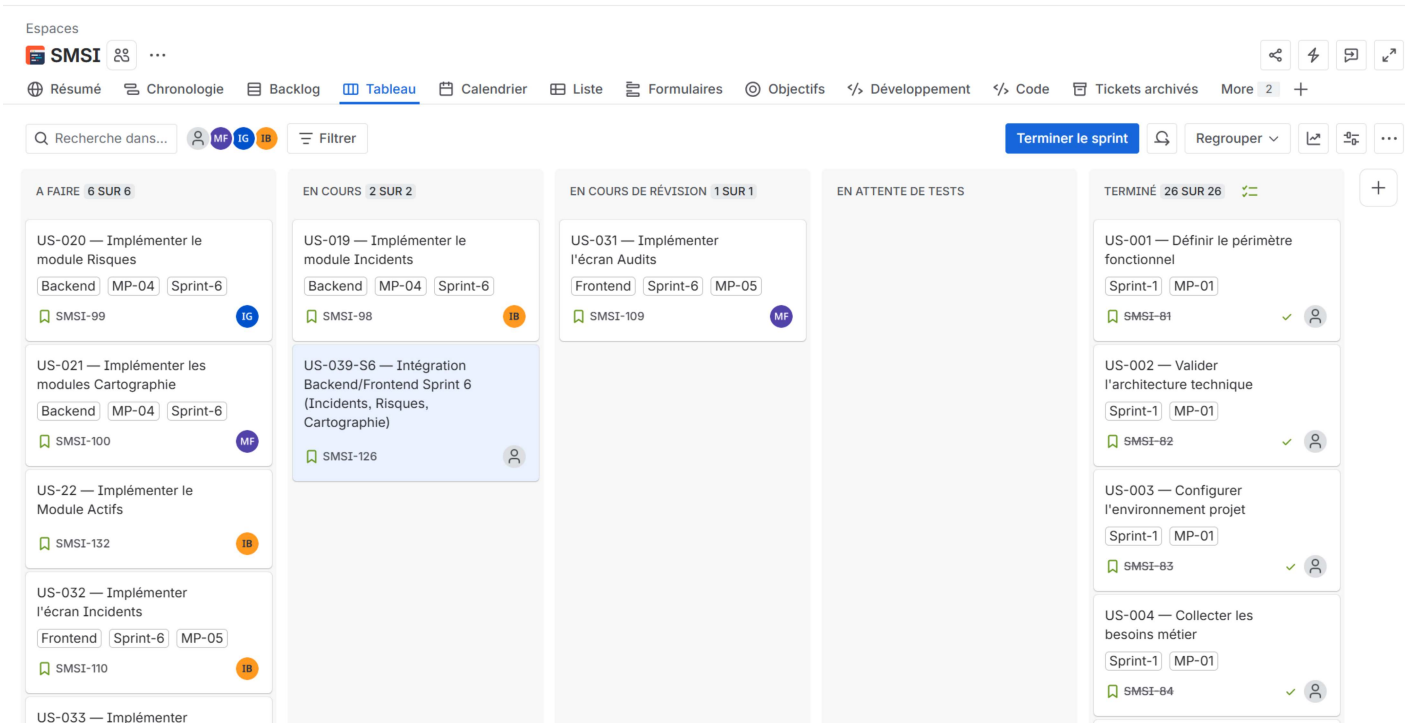


Figure 1.10: Tableau de suivi

1.3.4 Diagramme de Gantt

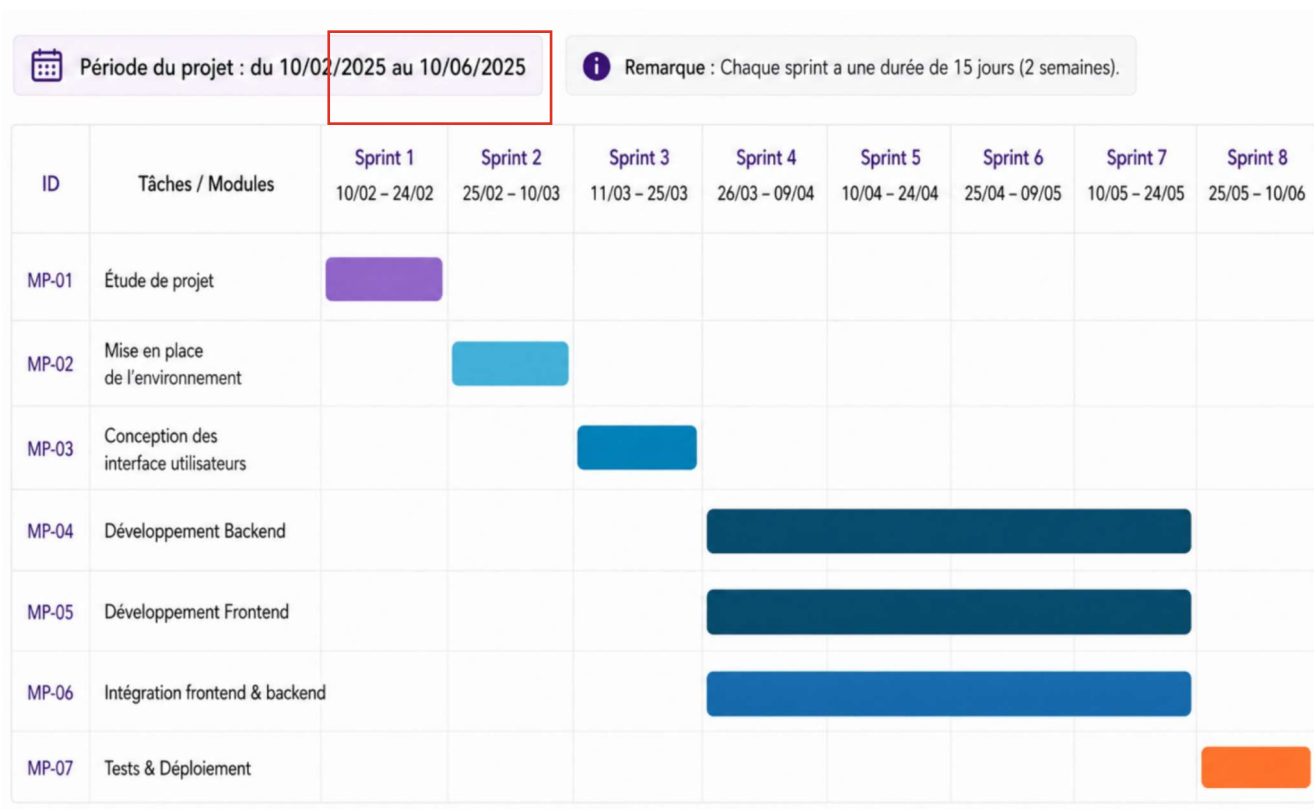


Figure 1.11: Diagramme de Gantt

Conclusion

Au cours de ce chapitre, le périmètre du projet a été clairement défini, tout comme la méthodologie adoptée et le planning mis en place pour sa réalisation. Le chapitre suivant sera consacré à la phase d'analyse et de spécification du système à développer, dans le but de mieux cerner les besoins des utilisateurs et de concevoir une solution en adéquation avec leurs attentes.

Chapitre 2

Analyse et spécification des besoins

Introduction

Ce chapitre établit les bases conceptuelles et méthodologiques du projet. Il commence par une étude des solutions existantes et une analyse de faisabilité (technique, organisationnelle et économique) afin de valider la pertinence du projet. Ensuite, il présente les besoins fonctionnels et non fonctionnels du système. Enfin, ces éléments sont formalisés dans un cahier des charges servant de référence pour la suite (conception et développement). L'objectif est d'assurer une vision claire, cohérente et viable du projet, en alignant les besoins métier avec les solutions techniques.

2.1 Étude de l'existant et de faisabilité

2.1.1 Étude d'existant

Dans le cadre de la conception de notre plateforme dédiée à la gestion du Système de Management de la Sécurité de l'Information (SMSI) conforme à la norme ISO 27001, il est essentiel de réaliser une étude de l'existant. Cette étape permet d'identifier les solutions déjà disponibles sur le marché, d'analyser leurs fonctionnalités, ainsi que leurs avantages et leurs limites.

L'objectif de cette analyse est de mieux comprendre les approches adoptées par les outils existants en matière de gestion des risques, de conformité et d'audit, tout en mettant en évidence les insuffisances auxquelles les organisations peuvent être confrontées. Cette étude constitue ainsi une base de réflexion pour proposer une solution innovante, mieux adaptée aux besoins réels des entreprises, notamment en termes de centralisation, d'automatisation et de simplicité d'utilisation.

Table 2.1: Étude de l'existant des solutions SMSI

Solution	Fonctionnalités principales	Avantages	Limites
EBIOS RM Tool	- Analyse des risques (EBIOS) - Identification des menaces - Évaluation des risques	- Méthode reconnue (ANSSI) - Structuration claire des risques	- Pas de gestion complète SMSI - Interface peu intuitive
Excel / Outils manuels	- Suivi des actifs - Gestion des contrôles - Tableaux personnalisés	- Simple à utiliser - Flexible	- Pas d'automatisation - Risque d'erreurs élevé - Difficulté de suivi en temps réel
Outils GRC (ex : ServiceNow, RiskWatch)	- Gestion des risques - Suivi conformité - Reporting	- Solutions complètes - Automatisation	- Coût élevé - Complexité d'utilisation - Peu adaptées aux PME
Solution proposée (ISMS Manager)	- Gestion complète SMSI - Suivi ISO 27001 - Gestion audits, risques, PDCA - Tableau de bord centralisé	- Centralisation totale - Automatisation des processus - Multi-sociétés	- En cours de développement - Nécessite maintenance

2.1.2 Étude de faisabilité

L'étude de faisabilité constitue une étape essentielle permettant d'évaluer la capacité de réalisation du projet dans différentes dimensions. Elle vise à analyser si le projet est réalisable sur les plans technique, organisationnel et économique, tout en identifiant les éventuelles contraintes.

2.1.2.1 Faisabilité technique

La faisabilité technique consiste à vérifier si les technologies et les outils choisis permettent de réaliser le projet dans de bonnes conditions.

Dans notre cas, le développement de la plateforme repose sur des technologies modernes et maîtrisées, notamment ASP.NET Core pour le backend, React.js pour le frontend, ainsi qu'une base de données SQL Server. L'architecture adoptée (CQRS et Clean Architecture) garantit une bonne structuration du code, une maintenabilité élevée et une évolutivité du système.

De plus, les fonctionnalités prévues, telles que la gestion des risques, des audits, des contrôles ISO 27001 et du cycle PDCA, sont techniquement réalisables grâce aux frameworks utilisés. L'environnement de développement et les outils disponibles permettent également de tester, déployer et maintenir efficacement la solution.

Ainsi, d'un point de vue technique, le projet est jugé réalisable.

2.1.2.2 Faisabilité organisationnelle

La faisabilité organisationnelle évalue la capacité de l'organisation à mettre en œuvre le projet en termes de ressources humaines et de gestion.

Le projet est réalisé dans un cadre académique avec une équipe de développement disposant de compétences en développement web (frontend et backend), en gestion de bases de données et en conception logicielle. L'utilisation d'outils de gestion de projet (comme GitHub pour le versionnement et éventuellement Jira pour le suivi des tâches) facilite la coordination entre les membres de l'équipe.

Par ailleurs, le projet répond à un besoin réel des organisations souhaitant se conformer à la norme ISO 27001, ce qui renforce sa pertinence. L'organisation du travail, basée sur une répartition claire des tâches, permet d'assurer une progression structurée du projet.

Ainsi, les conditions organisationnelles sont favorables à la réalisation du projet.

2.1.2.3 Faisabilité économique

La faisabilité économique consiste à évaluer les coûts liés au projet ainsi que les bénéfices attendus. Dans le cadre de ce projet, les coûts sont relativement faibles, car les technologies utilisées sont majoritairement open source ou disponibles dans un environnement académique.

Les principaux coûts concernent le temps de développement, l'hébergement (éventuellement sur des plateformes cloud comme Azure) et la maintenance.

En contrepartie, la solution proposée permet de réduire considérablement les coûts liés à la gestion manuelle du SMSI, d'améliorer l'efficacité des audits, et de faciliter la conformité à la norme ISO 27001. Elle offre également un gain de temps important.

Ainsi, le projet présente un bon rapport coût/bénéfice, ce qui confirme sa viabilité économique.

2.2 Spécification des besoins fonctionnels et non fonctionnels

2.2.1 Besoins fonctionnels

Les besoins fonctionnels décrivent l'ensemble des fonctionnalités que le système doit offrir pour répondre aux objectifs métier de la plateforme SMSI. Ils sont organisés selon les domaines fonctionnels identifiés dans le backlog produit.

Administration, authentification et gestion multi-société

La plateforme doit permettre la gestion sécurisée de l'authentification des utilisateurs, avec support des mécanismes de contrôle d'accès basés sur les rôles (RBAC). Elle doit offrir la capacité de créer et d'administrer plusieurs sociétés (tenants) de manière totalement isolée, garantissant l'étanchéité des données entre entités. Un administrateur doit pouvoir créer, modifier, désactiver des comptes utilisateurs et les rattacher à une société et un rôle définis. La plateforme doit également consigner l'ensemble des accès et des actions sensibles dans des journaux d'audit consultables par le RSSI.

Gestion des rôles et des permissions

Le système doit permettre la configuration de rôles métier finement paramétrables : Administrateur, RSSI, Responsable SMSI, Analyste Risque, Auditeur, Valideur et utilisateur standard. Chaque rôle doit disposer d'un ensemble de permissions configurables sur les modules, les objets et les actions (lecture, écriture, validation, export). La matrice des droits doit être applicable par société et par module de façon indépendante.

Cartographie des processus et référentiels

La plateforme doit permettre la modélisation des processus métier de l'organisation, leur organisation par catégories et taxonomie, ainsi que l'établissement de liens sémantiques entre processus, clauses ISO, contrôles, actifs et documents. Cette cartographie constitue le référentiel central structurant l'ensemble du SMSI.

Gestion documentaire

Le système doit offrir une gestion documentaire complète incluant le dépôt, le versionnage, la classification et la recherche de documents. Un workflow d'approbation doit permettre à un valideur de publier officiellement un document après revue. Les documents doivent pouvoir être rattachés à des contrôles, des clauses ISO ou des actifs, assurant ainsi la traçabilité des preuves.

Suivi de la conformité ISO

La plateforme doit permettre la tenue d'un registre exhaustif des clauses et exigences des référentiels ISO applicables, notamment ISO 27001. Pour chaque clause, un évaluateur doit pouvoir renseigner un statut de conformité, joindre des preuves documentaires et saisir des commentaires. L'historique des évaluations doit être conservé et consultable.

Gestion des contrôles

Le système doit permettre la définition d'un référentiel de contrôles de sécurité lié aux clauses ISO. Les analystes doivent pouvoir planifier et exécuter des tests de contrôle, en enregistrant les résultats, les preuves associées et l'historique des évaluations successives.

Gestion des actifs informationnels

La plateforme doit offrir un module d'inventaire des actifs permettant d'enregistrer chaque actif, son propriétaire, sa classification et sa criticité selon les critères de Confidentialité, d'Intégrité et de Disponibilité (C/I/D). Les actifs doivent être liés aux contrôles et aux processus pour alimenter l'analyse de risque.

Analyse des risques selon EBIOS RM

Le système doit implémenter la méthode EBIOS Risk Manager dans sa structure complète : saisie des biens essentiels et des événements redoutés, construction de scénarios de menace, cotation des risques selon les axes impact et vraisemblance, génération d'une heatmap de risques, et validation du plan de traitement par la direction. L'ensemble du registre des risques doit être versionné et exportable.

Gestion des incidents de sécurité

La plateforme doit intégrer un module de gestion des incidents de sécurité permettant de déclarer, classer, suivre et clôturer les incidents affectant la confidentialité, l'intégrité ou la disponibilité des actifs informationnels. Chaque incident doit être associé à une date, un niveau de criticité, un responsable de traitement et un plan de remédiation. Le système doit permettre le suivi du cycle de vie complet de

l'incident : détection, analyse, confinement, résolution et retour d'expérience. Les incidents doivent pouvoir être liés aux actifs concernés, aux risques identifiés et aux actions correctives PDCA afin d'assurer une traçabilité complète des événements de sécurité.

Plans d'actions PDCA

La plateforme doit intégrer un module de pilotage des actions d'amélioration continue selon le cycle PDCA (Plan-Do-Check-Act). Un responsable SMSI doit pouvoir créer, affecter, suivre et clôturer des actions correctives ou préventives, avec indicateurs d'avancement et alertes sur les échéances.

Gestion des audits internes

Le système doit permettre la planification d'un programme annuel d'audits, la génération automatique de checklists à partir des contrôles, documents et actifs référencés, ainsi que la traçabilité des non-conformités (NC), opportunités d'amélioration (OFI) et actions correctives associées. Un rapport d'audit structuré doit être générable et exportable au format PDF ou Word.

Gestion des formations de sensibilisation

Le système doit permettre la planification et le suivi des campagnes de sensibilisation à la sécurité de l'information destinées aux collaborateurs. Un responsable SMSI doit pouvoir créer des sessions de formation, affecter des participants, suivre les taux de participation et enregistrer les résultats des évaluations éventuelles. La plateforme doit conserver un historique des formations suivies par chaque utilisateur et produire des indicateurs permettant de mesurer le niveau de sensibilisation global de l'organisation.

Gestion des fournisseurs

La plateforme doit permettre la gestion des fournisseurs et des tiers ayant accès aux systèmes d'information ou aux données de l'organisation. Chaque fournisseur doit être enregistré avec ses informations contractuelles, son niveau de criticité et les services associés. Le système doit permettre d'évaluer les risques liés aux fournisseurs, d'associer des clauses contractuelles de sécurité et de suivre les audits ou évaluations périodiques réalisés sur les tiers. Les fournisseurs doivent pouvoir être liés aux actifs, aux risques et aux contrôles de sécurité concernés.

Gestion des parties prenantes

Le système doit permettre l'identification et la gestion des parties prenantes internes et externes intervenant dans le SMSI. Pour chaque partie prenante, il doit être possible d'enregistrer les attentes, exigences, obligations réglementaires et niveaux d'influence associés. La plateforme doit permettre d'établir des liens entre les parties prenantes, les processus métier, les risques et les objectifs de sécurité afin de faciliter l'analyse du contexte organisationnel conformément aux exigences de la norme ISO 27001.

Tableau de bord KPI SMSI

La plateforme doit fournir un dashboard consolidé présentant les indicateurs clés de performance du SMSI : taux de conformité par clause, taux d'évaluation des contrôles, niveau de risque résiduel, état d'avancement des audits et des plans d'actions. Une fonctionnalité de drill-down doit permettre à un manager de filtrer les indicateurs par société ou par processus.

Assistant conversationnel local (Chatbot)

En mode pilote, la plateforme doit intégrer un assistant conversationnel capable de répondre à des questions portant sur la documentation interne de l'organisation. Les réponses doivent être filtrées par les droits RBAC de l'utilisateur connecté, garantissant qu'aucune information confidentielle ne soit exposée en dehors du périmètre autorisé.

2.2.2 Besoins non fonctionnels

Les besoins non fonctionnels définissent les contraintes de qualité, de performance et de sécurité que le système doit respecter, indépendamment des fonctionnalités métier.

Performance

La plateforme doit garantir des temps de réponse acceptables pour l'ensemble des utilisateurs connectés simultanément. Les pages principales du tableau de bord doivent se charger en moins de 3 secondes dans des conditions normales d'utilisation. Les requêtes de reporting et de génération de documents ne doivent pas dépasser 10 secondes.

Sécurité

L'ensemble des communications entre le client et le serveur doit être chiffré via le protocole HTTPS/TLS. Les mots de passe doivent être stockés sous forme hachée (bcrypt ou équivalent). Le système doit mettre en œuvre une protection contre les attaques courantes : injection SQL, XSS, CSRF et force brute. Les sessions utilisateurs doivent expirer automatiquement après une période d'inactivité configurable.

Disponibilité et fiabilité

La plateforme doit viser un taux de disponibilité d'au moins 99% en dehors des fenêtres de maintenance planifiées. Un mécanisme de sauvegarde automatique des données doit être mis en place, avec une fréquence quotidienne minimale et une procédure de restauration documentée.

Scalabilité

L'architecture du système doit permettre une montée en charge progressive, notamment en termes de nombre de sociétés (tenants), d'utilisateurs simultanés et de volume de données stockées. L'adoption de l'architecture Clean Architecture et du pattern CQRS facilite cette évolutivité.

Maintenabilité

Le code source doit respecter les principes SOLID et être accompagné d'une documentation technique suffisante pour faciliter les évolutions futures. Les modules doivent être découplés afin de permettre des mises à jour indépendantes sans impact sur l'ensemble du système.

Portabilité

La plateforme doit être accessible depuis les navigateurs web modernes (Chrome, Firefox, Edge, Safari) sans installation préalable côté client. L'interface doit être responsive et s'adapter correctement aux différentes résolutions d'écran, notamment les ordinateurs de bureau et les tablettes.

Traçabilité

Toutes les actions critiques effectuées sur la plateforme (création, modification, suppression, validation) doivent être enregistrées dans un journal d'audit horodaté et non modifiable, accessible uniquement aux profils autorisés.

Conformité réglementaire

La solution doit respecter les exigences du Règlement Général sur la Protection des Données (RGPD) en matière de traitement et de stockage des données personnelles. Elle doit également s'aligner sur les recommandations de la norme ISO 27001 en termes de gouvernance et de documentation.

Ergonomie et accessibilité

L'interface utilisateur doit être intuitive, cohérente et accessible à des utilisateurs ayant des profils variés (techniques et non techniques). Les messages d'erreur doivent être clairs et orientés vers la résolution du problème. La plateforme doit supporter au minimum les langues française et anglaise.

2.3 Rédaction du cahier des charges

2.3.1 Spécifications fonctionnelles

Le cahier des charges fonctionnel synthétise l'ensemble des fonctionnalités attendues de la plateforme SMSI, telles qu'elles ont été identifiées lors de la phase d'analyse des besoins. La solution doit couvrir l'intégralité du cycle de vie d'un Système de Management de la Sécurité de l'Information conforme à la norme ISO 27001, depuis la cartographie des processus et la gestion des actifs jusqu'au suivi des audits, des risques et des plans d'actions PDCA.

Les fonctionnalités prioritaires identifiées sont les suivantes : la gestion multi-société avec isolation des données, le contrôle d'accès basé sur les rôles (RBAC), la gestion documentaire avec workflow

d'approbation, le suivi de la conformité par clause ISO, l'analyse des risques selon la méthode EBIOS RM, la gestion des incidents de sécurité, le pilotage des audits internes et le tableau de bord KPI consolidé.

Ces fonctionnalités constituent le périmètre minimal viable (MVP) de la plateforme et servent de référence pour la phase de conception et de développement.

2.3.2 Spécifications techniques

Sur le plan technique, la plateforme repose sur une architecture moderne et découplée. Le backend est développé en **ASP.NET Core** selon les principes de la **Clean Architecture** et du pattern **CQRS** (Command Query Responsibility Segregation), garantissant une séparation claire des responsabilités et une maintenabilité élevée. Le frontend est développé en **React.js** avec une interface responsive compatible avec les navigateurs modernes. La persistance des données est assurée par **SQL Server**, avec une gestion multi-tenant garantissant l'isolation des données entre sociétés.

L'authentification est gérée via des tokens **JWT** (JSON Web Token), et les communications sont sécurisées par le protocole **HTTPS**. Le déploiement est prévu sur une infrastructure cloud (Microsoft Azure), avec des pipelines CI/CD pour automatiser les phases de test et de mise en production. Le versionnement du code source est assuré via **Git/GitHub**.

Conclusion

Ce chapitre a permis de poser les fondations méthodologiques et fonctionnelles du projet. L'étude de l'existant a mis en évidence les limites des solutions actuelles, qu'il s'agisse d'outils manuels comme Excel, de méthodologies spécialisées comme EBIOS RM Tool, ou de plateformes GRC coûteuses et complexes. Ces constats ont motivé le développement d'une solution centralisée, automatisée et adaptée aux besoins réels des organisations souhaitant se conformer à la norme ISO 27001.

L'analyse de faisabilité a confirmé la viabilité du projet sur les plans technique, organisationnel et économique. Les technologies retenues, les compétences disponibles et le rapport coût-bénéfice favorable constituent des conditions favorables à la réussite du projet.

L'identification des besoins fonctionnels et non fonctionnels a permis de délimiter précisément le périmètre de la plateforme SMSI, en couvrant l'ensemble des domaines clés : gestion des risques, des audits, de la conformité, des actifs, des incidents et du cycle PDCA. Ces besoins ont été formalisés dans un cahier des charges servant de référence tout au long du cycle de développement.

Le chapitre suivant s'attachera à traduire ces spécifications en une conception architecturale et fonctionnelle détaillée, constituant ainsi le socle de la phase de développement.